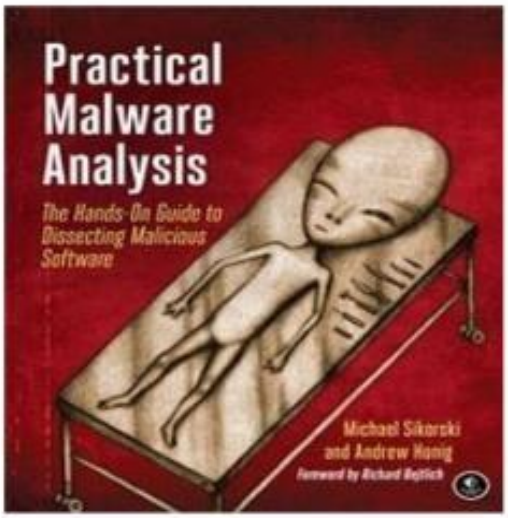
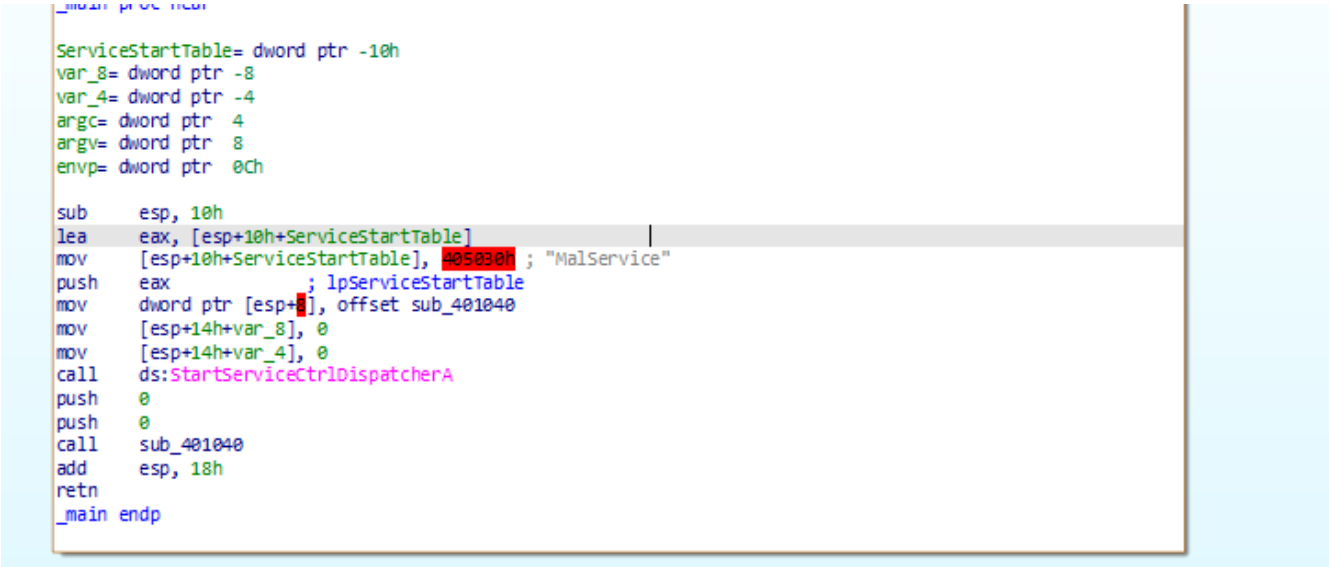
PMA lab 7 Write-up





https://www.linkedin.com/in/talha-yaqoob



```
ServiceStartTable= dword ptr -10h
var_8= dword ptr -8
var_4= dword ptr -4
argc= dword ptr  4
argv= dword ptr  8
envp= dword ptr  0Ch

sub     esp, 10h
lea     eax, [esp+10h+ServiceStartTable]
mov     [esp+10h+ServiceStartTable], 405030h ; "MalService"
push    eax             ; lpServiceStartTable
mov     dword ptr [esp+8], offset sub_401040
mov     [esp+14h+var_8], 0
mov     [esp+14h+var_4], 0
call    ds:StartServiceCtrlDispatcherA
push    0
push    0
call    sub_401040
add     esp, 18h
retn
_main endp
```

here is the main function of the binary

1. How does this program ensure that it continues running (achieves persistence) when the computer is restarted?

To achieve persistence we can see that the malware uses the the API

```
call    ds:StartServiceCtrlDispatcherA
```

when malware calls **StartServiceCtrlDispatcherA,** it's trying to become a *Windows service*

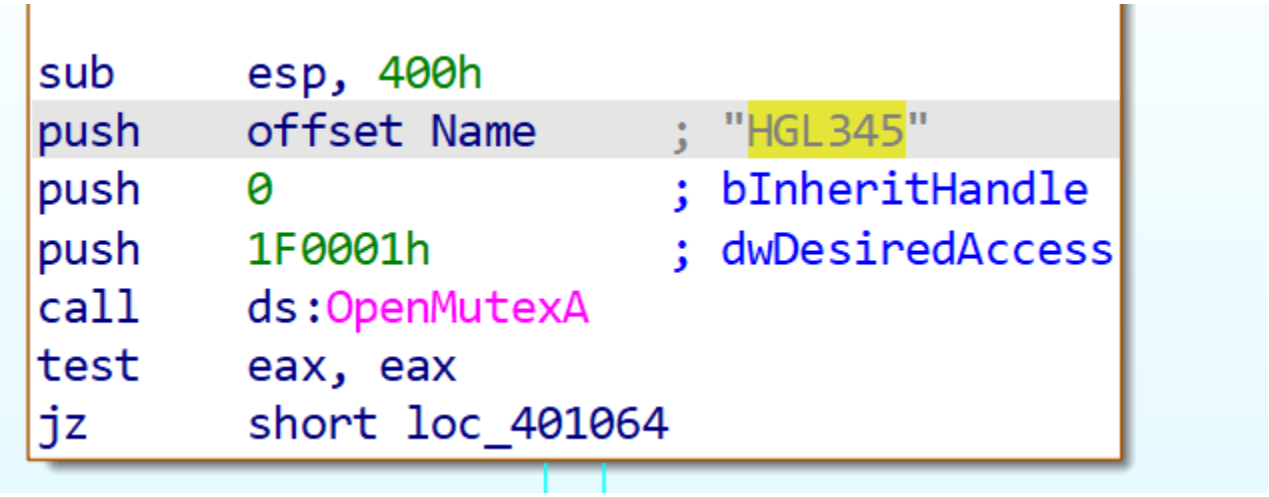
A **service** (in Windows) is a **program that runs in the background, without a user, from boot to shutdown**, managed by the OS. So when a Malware calls it it is trying to achieve persistence

Why does this program use a mutex?

What is a mutex ?

A mutex is a windows kernel object which is created and managed by the OS that allows only one thread or process to access a shared resource at a time.

when we visit the sub-routine 401040 . There is a check for mutex named "HGL345"

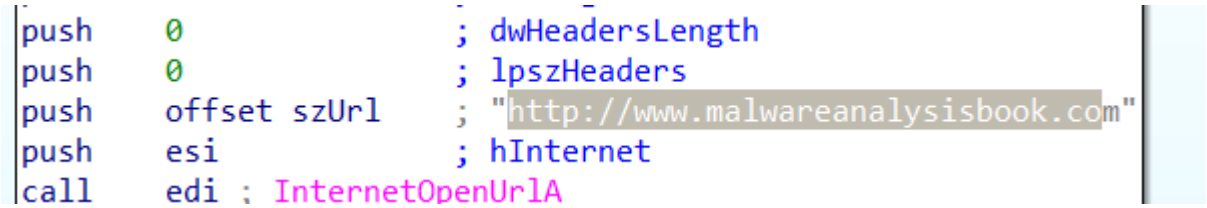


the check is trying to open a mutex named **"HGL345"** to check if another copy of the program is already running. If so the function is terminated other wise

3. What is a good host-based signature to use for detecting this program?

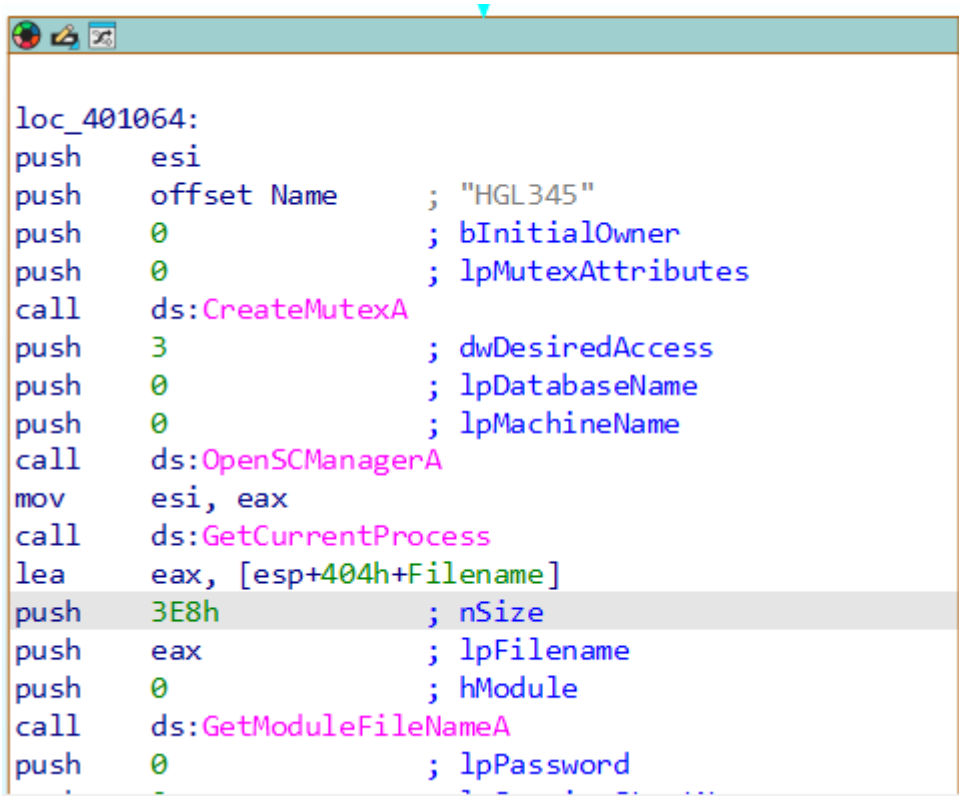
The best host-based signature for this program is that it is registering itself as a service named “Malservice” using the API **StartServiceCtrlDispatcherA**

4. What is a good network-based signature for detecting this malware?



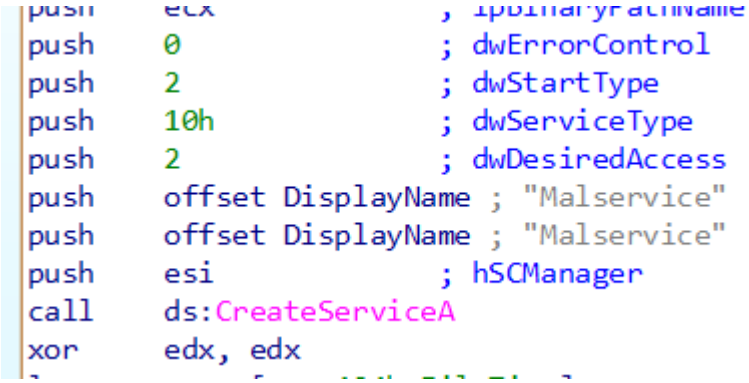
the URL http://www.malwareanalysisbook.com will be a good network-based indicator for this program

What is the purpose of this program?



```
loc_401064:
push    esi
push    offset Name     ; "HGL345"
push    0               ; bInitialOwner
push    0               ; lpMutexAttributes
call    ds:CreateMutexA
push    3               ; dwDesiredAccess
push    0               ; lpDatabaseName
push    0               ; lpMachineName
call    ds:OpenSCManagerA
mov     esi, eax
call    ds:GetCurrentProcess
lea     eax, [esp+404h+Filename]
push    3E8h            ; nSize
push    eax             ; lpFilename
push    0               ; hModule
call    ds:GetModuleFileNameA
push    0               ; lpPassword
```

1.Creates the Mutex
2.Opens Windows service Control Manager
3.Gives the full path of the currently running file



```
push    ecx             ; lpBinaryPathName
push    0               ; dwErrorControl
push    2               ; dwStartType
push    10h             ; dwServiceType
push    2               ; dwDesiredAccess
push    offset DisplayName ; "Malservice"
push    offset DisplayName ; "Malservice"
push    esi             ; hSCManager
call    ds:CreateServiceA
xor     edx, edx
```

and then registering itself as a service called **Malservice** that runs on startup.

The Program register itself as a Windows service and then checks that either it is running or not .Later it tries to access the URL that too after it executes which is in year 2100

When will this program finish executing?

```
mov     [esp+40Ch+SystemTime.wYear], 2100
call    ds:SystemTimeToFileTime
push    0               ; lpTimerName
push    0               ; bManualReset
push    0               ; lpTimerAttributes
call    ds:CreateWaitableTimerA
push    0               ; fResume
push    0               ; lpArgToCompletionRoutine
```

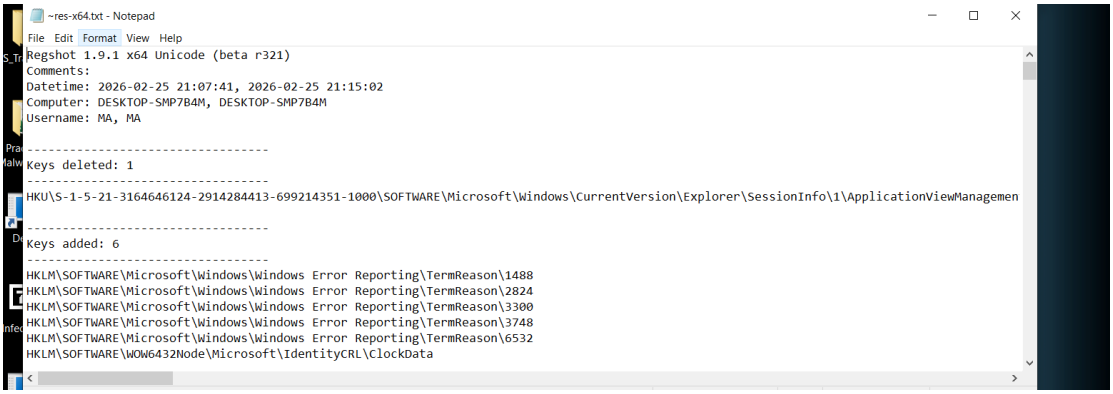
The program will finish executing only if it starts in the first place, which won't be happening till the year 2100 which won't be happening anytime soon.

Lab 7-3

For this lab, we obtained the malicious executable, Lab07-03.exe, and DLL, Lab07-03.dll, prior to executing. This is important to note because the mal ware might change once it runs. Both files were found in the same directory on the victim machine. If you run the program, you should ensure that both files are in the same directory on the analysis machine. A visible IP string beginning with 127 (a loopback address) connects to the local machine. (In the real version of this malware, this address connects to a remote machine, but we've set it to connect to localhost to protect you.) WARNING This lab may cause considerable damage to your computer and may be difficult to remove once installed. Do not run this file without a virtual machine with a snapshot taken prior to execution.

1. How does this program achieve persistence to ensure that it continues running when the computer is restarted?

for this I actually used regshot to monitor changes in the registry but the malware does nothing there to achieve persistence

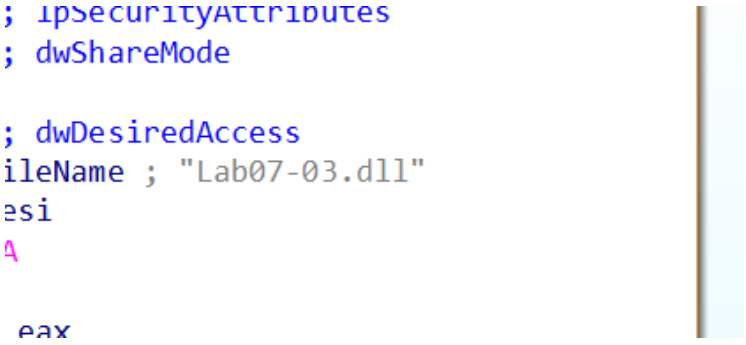


How persistence is achieved here:

1. Malware copies itself into C:\Windows\System32
2. Uses a fake Windows-looking name (kerne132.dll)
3. Leaves the file there permanently
4. Waits for another program or stage to load it later

2. What are two good host-based signatures for this malware?

we have 2 host-based indicators the first one is



Lab07-03.dll

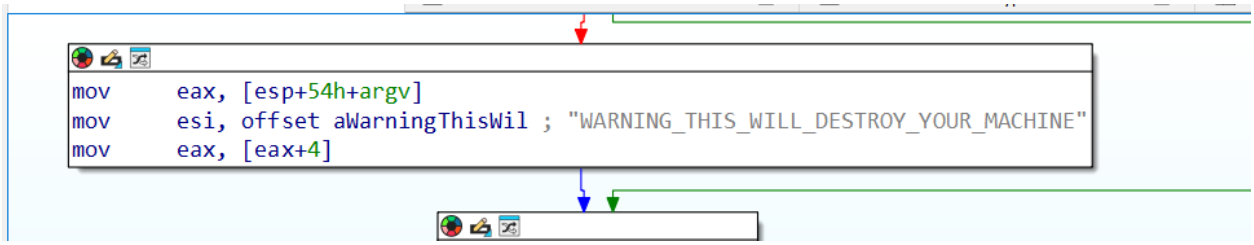
the other one is

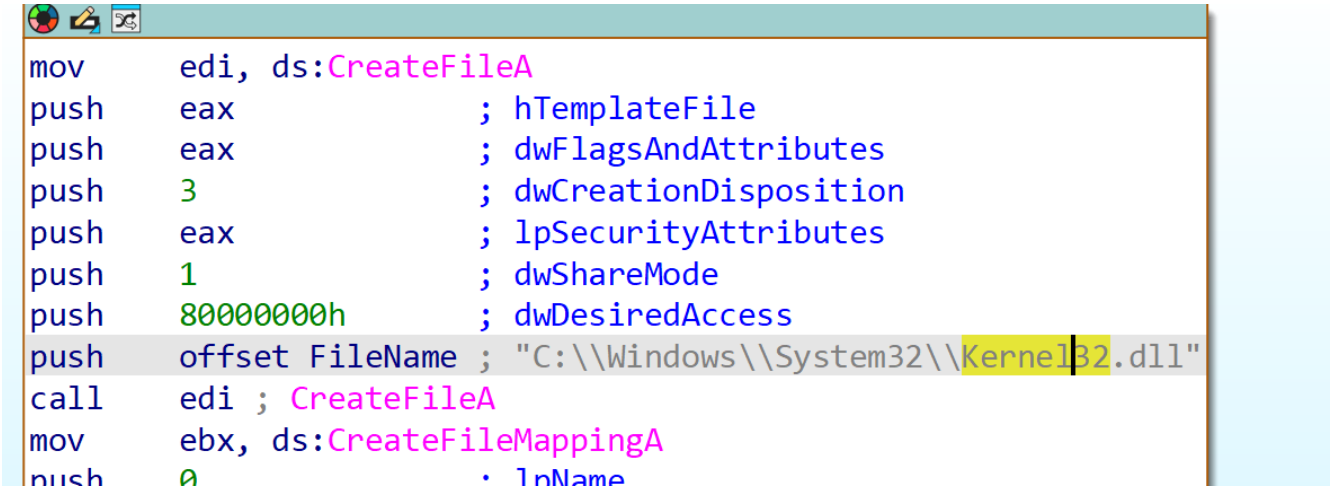
kerne132.dll

```
DFallitExists
; "C:\\windows\\system32\\kerne132.dll'
eName ; "Lab07-03.dll"
```

3. What is the purpose of this program?

First of all the program executes only by Command line argument





after that the malware maps the kernel32.dll into the memory .

\\

```
call    esi ; CloseHandle
push    0                   ; bFailIfExists
push    offset NewFileName ; "C:\\windows\\system32\\kerne132.dll"
push    offset ExistingFileName ; "Lab07-03.dll"
```

the later trick of this malware is that It trying to replace the Lab07-03 dll as “kerne132.dll” in the system32 folder

This Technique is called dll masquerading

to understand more about how the malware works we will look at the decompiled formed of the binary

```
ateFileA(s_C:\Windows\System32\Kernel32.dll_0040308c,0x80000000,1,
         (LPSECURITY_ATTRIBUTES)0x0,3,0,(HANDLE)0x0);
ateFileMappingA(hFile,(LPSECURITY_ATTRIBUTES)0x0,2,0,0,(LPCSTR)0x
ViewOfFile(pvVar6,4,0,0,0);
ateFileA(s_Lab07-03.dll_0040307c,0x10000000,1,(LPSECURITY_ATTRIBU
```

here ghidra shows us that the kernel32.dll us being opened from the System32 path

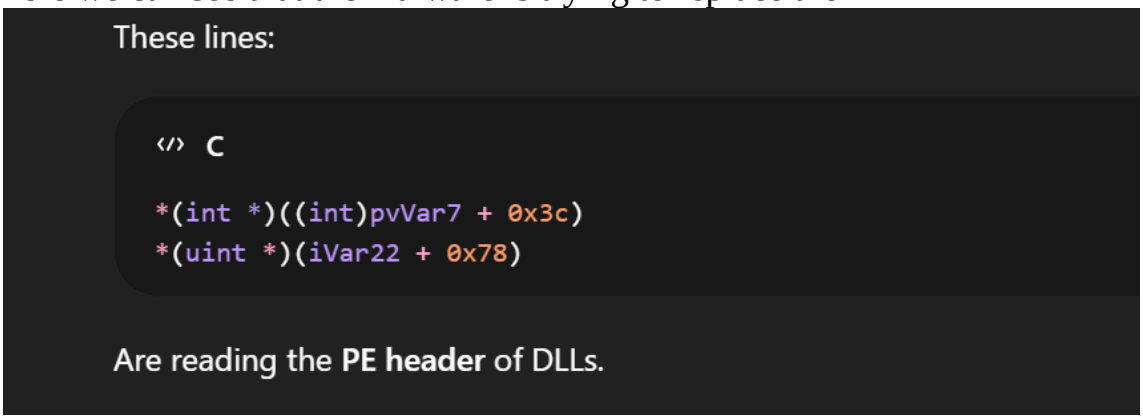
CreateFileMapping
MapViewOfFile

Means : “Put Kernel32.dll into my memory.”

Now the program has a full copy of that Windows file inside itself.

as we know the PE format of the dll and exe ois the same in Windows OS

here we can see that the malware is trying to replace the



And after replacing imports

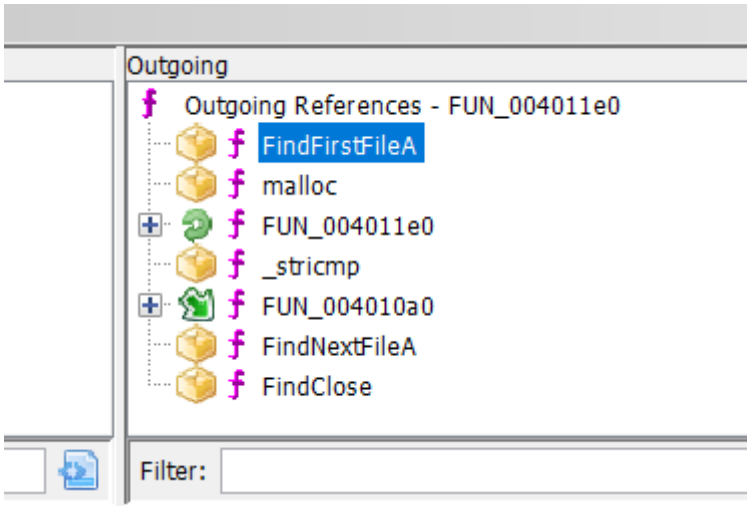
later the malware is copying the chunks of the dll

later the malware is rebuilding imports for the Twin DLL it is about to create named “kernel132.dll”

```
07
08
09 07-03.dll_0040307c,s_C:\windows\system32\kerne132.dll_0040304c,0)
10
```

The “kernel132.dll” will be also be placed into the system32

This malware reads the real kernel32.dll, copies its structure into memory, injects malicious code from Lab07-03.dll, and builds a fake DLL that looks legitimate. It then copies the malicious DLL into C:\Windows\System32 as kerne132.dll so it can be loaded later for persistence.



The fun 004011e0 is a function which iterates through the “C” directory and check whether the file is exe or not if it is not it skips otherwise

I wasn’t able to anayzle it at much deeper level but I would make a logical guess that the binary will replace the functionality of any of the exe(s) calling the kernel32.dll with kernel132.dll which would corrupt the whole computer

4. How could you remove this malware once it is installed?

Based on the assumption that the malware is a file infector , the malware can only be removed by completing rebooting the system and installing new windows since the file files are infected internally but the virus there is nothing much that can be done